

Security Assessment Report

Basic Web Application Security Assessment

Assessment Environment: PortSwigger Web Security Academy controlled training labs

Objective: To understand basic cybersecurity concepts and identify common web application security risks in a safe, authorized testing environment.

1. Scope and Methodology

The assessment was performed only against intentionally vulnerable labs provided by PortSwigger Web Security Academy. Manual testing was used to observe how the application handled user input and access to administrative functionality.

Tools Used: Web browser and PortSwigger Web Security Academy.

2. Summary of Findings

No.	Vulnerability	Severity
1	SQL Injection	High
2	Reflected Cross-Site Scripting (XSS)	Medium
3	Unprotected Admin Functionality	High

3. SQL Injection

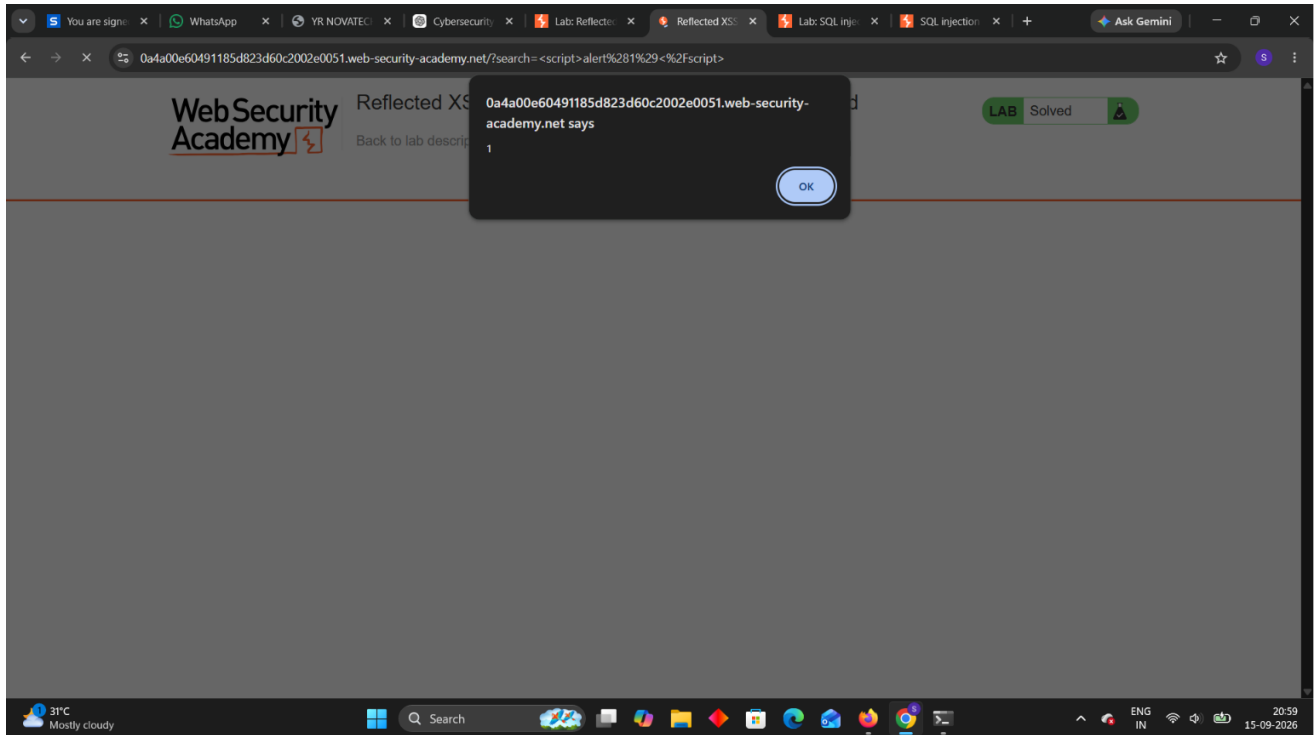
Severity: High

Description: SQL Injection occurs when user input is improperly handled and can alter a database query.

Observation: The category input was modified in the training lab and the application displayed hidden/unreleased products.

Impact: An attacker could potentially access or manipulate database information.

Recommendation: Use parameterized queries/prepared statements and validate input. Avoid constructing SQL queries directly from untrusted input.



Evidence 1 – SQL Injection

4. Reflected Cross-Site Scripting (XSS)

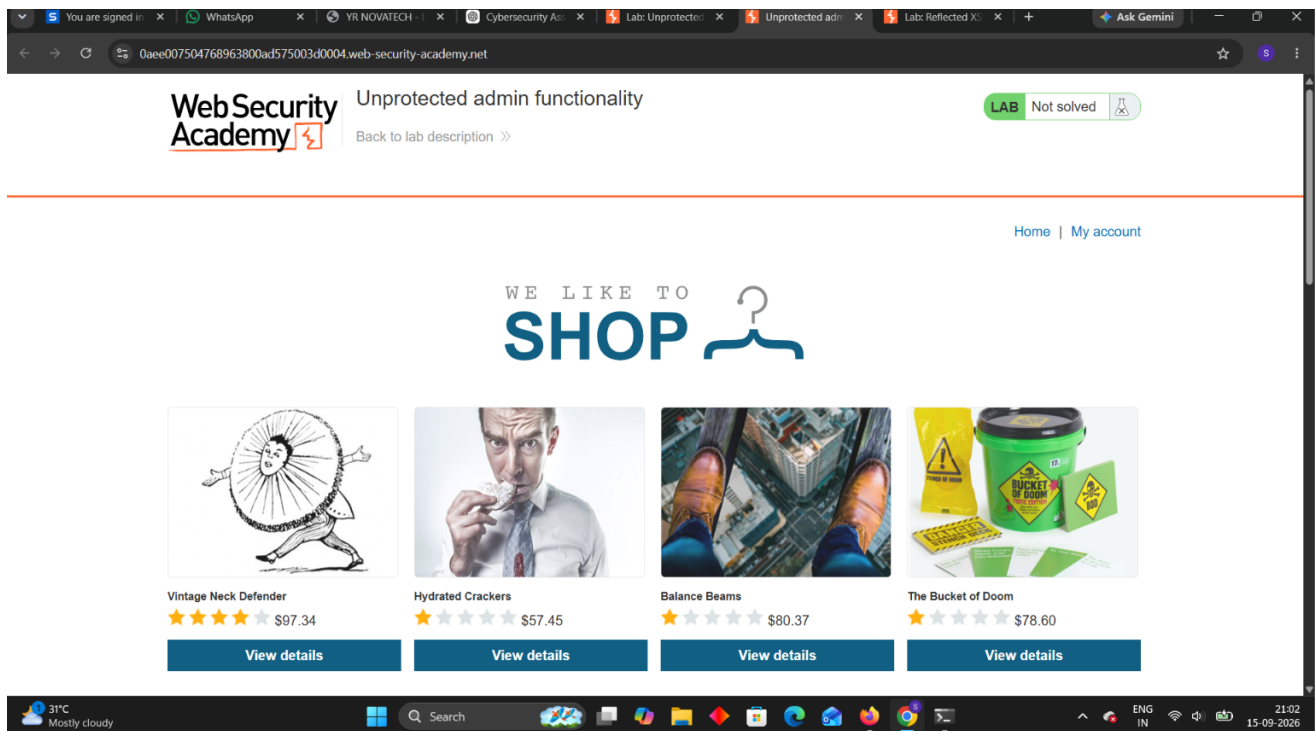
Severity: Medium

Description: Reflected XSS occurs when user-controlled input is returned to a web page and executed as script in a browser.

Observation: A test script entered through the lab's search functionality executed and displayed a browser alert.

Impact: An attacker may be able to execute unwanted JavaScript in a victim's browser.

Recommendation: Validate input and apply appropriate output encoding. Use secure frameworks and a suitable Content Security Policy where appropriate.



Evidence 2 – Reflected XSS

5. Unprotected Admin Functionality

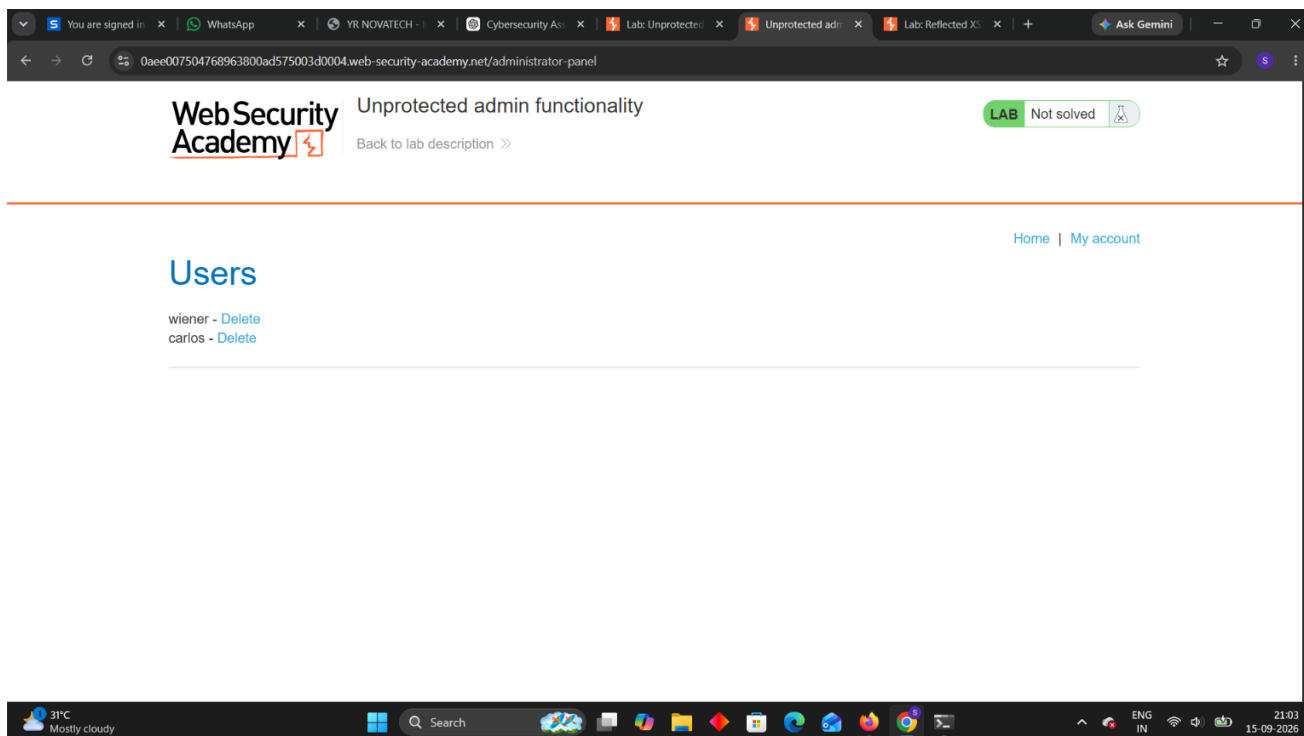
Severity: High

Description: Administrative functionality should be protected by proper authentication and authorization controls.

Observation: The training lab exposed an administrator panel through the discovered /administrator-panel path, including user-management functions.

Impact: Unauthorized users could potentially access or modify administrative functions.

Recommendation: Enforce server-side authentication and authorization checks on every administrative endpoint. Do not rely on hidden URLs or robots.txt for access control.



Evidence 3 – Unprotected Admin Functionality

6. Overall Recommendations

- Use secure coding practices and parameterized database queries.
- Validate and safely encode user-controlled input.
- Implement strong authentication and server-side authorization for administrative functions.
- Conduct regular vulnerability assessments and security testing.
- Keep application components and dependencies updated.

7. Conclusion

The assessment identified three common web application security risks: SQL Injection, Reflected XSS, and Unprotected Admin Functionality. These findings demonstrate the importance of secure input handling, output encoding, authentication, and authorization. Testing was performed only in controlled training labs.

8. Documentation

Training platform: PortSwigger Web Security Academy

GitHub documentation link: To be added after repository creation

Google Drive report link: To be added after upload